OffMenu: user-driven caching and enrichment

DESIGN ADDENDUM | 13 October 2026, Australia/Melbourne | Research and design only

Adopt an OffMenu-managed cache and enrichment service. Real scans, menu lookups and shopping activity should determine which permitted records are fetched, normalized, refreshed and made useful to later users. Direct user connections remain optional; the shared catalogue grows through actual demand and selected public releases.

The central decision is field-level promotion: OffMenu may privately process one response for a connected user while only admitting eligible facts from that response into a reusable catalogue. Anonymising a record and disclosing the practice in terms do not replace a provider's storage, derivative-use or redistribution permission. [S1-S4]

Layer	Purpose	Sharing rule
Transient response	Handle a permitted request without a durable payload copy.	For sources that prohibit retention, or until caching permission is established. No body logging.
Private cache	Fast reuse for one profile or explicitly authorised organisation.	Separate connection, entitlement and market scope. OffMenu hosts the cache; other users cannot read it.
Shared source assertions	Reusable product, ingredient, company, origin and recall facts.	Only the fields, audiences, territories and uses allowed by the source policy; public access is a separate permission.
Derived enrichment	Entity matches, ownership chains, dietary facts, normalized nutrients and basket comparisons.	Keep source dependencies and permitted uses. Derived data does not automatically become unrestricted.
Aggregate observations	Demand trends and permitted price/coverage statistics.	Separate privacy assessment, aggregation rules and provider permission; no public household history.

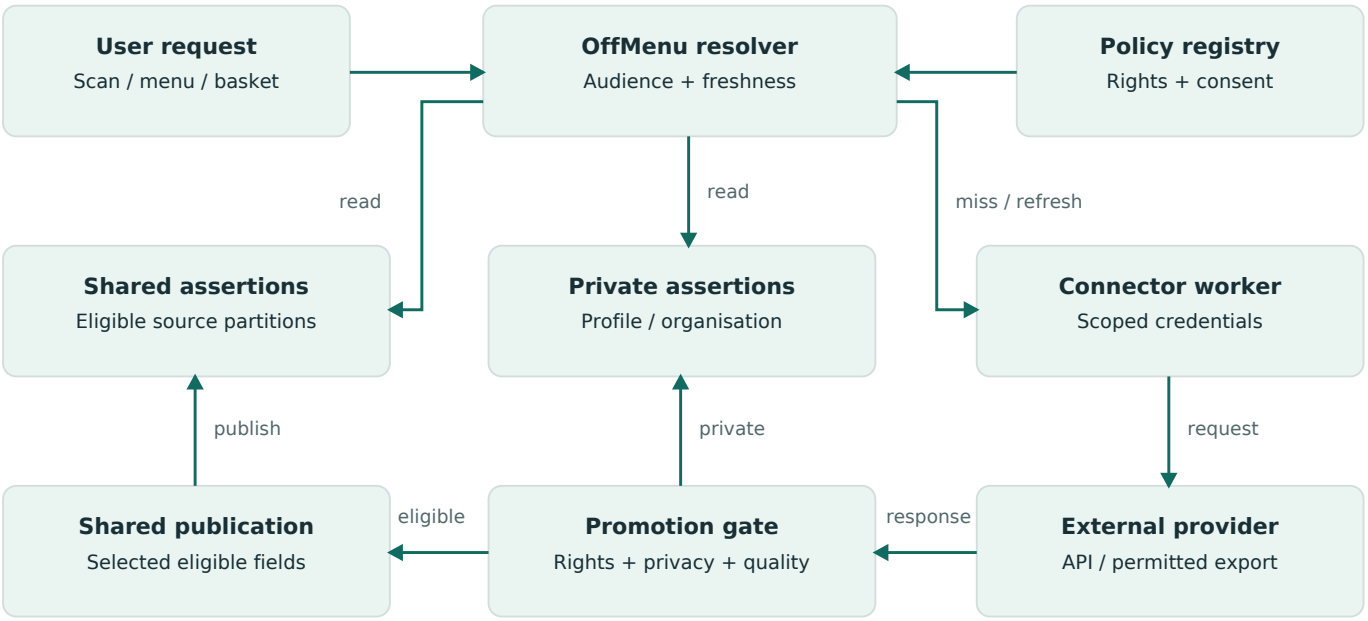
What this gives the product

A user does not need to connect every service. OffMenu first returns the reusable information it already has. A connection adds private capabilities and, where permitted, can also improve the shared catalogue. Declining optional contribution must not block ordinary scanning and private connection use.

This addendum builds on the 249-country enrichment discovery and its source IDs. It proposes behaviour and decision records, not a production schema or code change. Provider contracts and local-law applicability still require source-specific review before activation.

1. Architecture and request flow

Separate response caching from durable knowledge. A response cache saves calls; the assertion store preserves selected facts, history and evidence. Both sit behind the same authorisation and source-policy checks.



Reads return to the resolver, which composes the user's response. The diagram shows lookup and admission paths; caches are logical scopes, not necessarily separate vendors or servers. Refresh workers also re-check policy before fetching or committing.

Lookup lifecycle

1. Resolve identity: retain the GTIN as text, then market, label/recipe version, locale, store and requested fields. For a menu, include site, item and version.

2. Read eligible shared assertions and the requester's private records. Authorisation is checked on every cache hit, including search, exports and derived values.

3. Fetch only missing or stale fields from permitted sources. Prefer relevant public data; use the user's connection only for the intended service and authorised purpose.

4. Validate identifiers, units, dates and source scope. Persist only permitted content; normalize facts without dropping their source or rights.

5. Apply the promotion gate asynchronously. Return useful partial results immediately, with source dates and unknowns; do not wait for every enrichment provider.

2. Admission and reuse policy

Make source permission executable as a versioned policy, with overrides per endpoint, field, account tier, geography and contract. A paid account or successful API response is not a blanket data licence. [S1-S3]

Policy dimension	Record explicitly
Allowed actions	Proxy request; retain raw response; normalize fields; use derivatives; serve other users; aggregate; display; export; model training. Evaluate these separately.
Audience	Requester only, named organisation, named licensed cohort, all OffMenu users, or public. An authenticated common cache is not necessarily a public dataset.
Time and territory	Permitted countries, processing locations, contractual retention limit, attribution requirements, licence version, review date and expiry.
Credentials and budget	Who grants access, permitted scopes, OffMenu partner/application approval, scheduled-use permission, API quota and spend limits.
Privacy and contribution	Data category, purpose, user choice where applicable, consent/notice version, aggregation rules and restrictions on personal information.
Evidence and quality	Contract or licence link; reviewer and decision; field provenance; subject-match confidence; effective dates; required validation before publication.

Promotion rule

```
PROMOTE FIELD only when:
source permits this extraction and reuse
+ intended audience and territory are permitted
+ privacy/purpose requirements are satisfied
+ identity and quality checks pass
+ every input dependency permits the output use
```

Unknown rights means no shared promotion. If even private persistence is unconfirmed, use only an otherwise-authorised transient request. Do not place the raw result into a long-lived queue, debug log or dead-letter store as a workaround.

A response containing ingredients, a public product name and a personalised loyalty price can produce several assertions with different rights. Do not copy the entire response into a common cache merely because some fields are harmless.

Source-specific examples

Source class	Proposed treatment
GLEIF open data	Admit eligible company facts with provenance. Its published data are CC0; still assess any personal-data fields and evidence semantics. [S5]
Open Food Facts	Cache and enrich under its ODbL terms; retain attribution, rights and applicable share-alike obligations. Database, images and other assets need their own licence treatment. [S2]
Google Places	Do not mirror general content into the catalogue. Its policy restricts prefetching/storage subject to exceptions; place IDs have a stated caching exception. [S1]
Paid provider or retailer	Private by default until its actual agreement grants wider use. Negotiate aggregate/derived-data and shared-cache rights where they add enough value.

3. Identity, assertions and cache keys

Store assertions before choosing a preferred value. Multiple sources can disagree, cover different markets or describe different dates. A canonical record is a computed view over eligible evidence, not a destructive overwrite of the last response.

Record group	Minimum design fields
Identity	OffMenu entity ID; GTIN/GLN/LEI/registry IDs as strings; provider record ID; market, site, pack/recipe version; exact versus candidate match.
Fact	Predicate and value; units/basis; label language; effective-from/to; source-modified date; fetched-at and observed-at.
Provenance	Existing source_register source_id; source record/URL; source revision; permitted evidence reference; extractor/rule version; dependencies.
Rights	Source-policy version; licence/contract; allowed audience/actions/territories; attribution; fresh-until, retain-until and any access expiry.
Private control	Profile or organisation ID; connection grant reference; entitlement revision; purpose and contribution choice. Keep these out of public payloads.
Quality	Validation state; claimed/certified/inferred distinction; confidence with basis; conflicts; reviewer where necessary; withdrawal/supersession status.

Cache isolation

Shared keys include provider/endpoint, subject, market, locale, requested representation, source version and rights partition. Private keys additionally include the authorised principal, connection and entitlement revision. Price keys also need store, currency, unit, tax basis and offer conditions. Preserve HTTP Vary dimensions where applicable. [S6]

Never put a token, password, receipt body or raw personal identifier into a key, URL or log. Use an opaque connection reference to a credential vault. Physical deduplication of identical bytes must not deduplicate access rights, retention clocks or ownership of the record.

Derived records inherit constraints

A boycott match depends on the product-to-brand link and dated control chain. A non-GMO outcome depends on certificate scope and status. A normalized basket metric depends on quantity, edible portion, preparation basis and nutrient evidence. Preserve all these input IDs and the calculation version.

The output may be served only where all required input uses are permitted and licence obligations are compatible. If one essential parent is withdrawn or expires, invalidate or recompute the output. Public and proprietary inputs cannot be assumed compatible because they occupy different tables.

Matching and independent evidence

Preserve proposed entity matches separately from verified matches. An independently retrieved public record can supply its own evidence and rights, where that retrieval and matching are permitted. Re-labelling a copied restricted fact as an inference is not independent verification.

4. Freshness, retention and refresh cost

Keep three clocks separate: when a fact was valid, how long it may be presented as fresh, and how long it may be retained. Expiring a fast cache does not necessarily delete a licensed historical assertion; retention expiry does require deletion from the relevant stores.

Data type	Proposed starting behaviour	Stale behaviour
Price / availability	Minutes to hours for active products, within provider limits; validate again at order time.	Show timestamp and uncertainty; never present a historical or personalised quote as the current public price.
Menu / recipe / allergens	Provider events or change feeds first; short refresh windows for actively used menus.	Do not give a confident suitability result from an outdated or incomplete ingredient record.
Product / nutrition / origin	Version-aware fetch on demand; refresh active items in days, slower for cold items where suitable.	Keep recipe/label versions and source dates; do not silently merge different markets.
Ownership / certification	Transaction and suspension events plus scheduled refresh; respect certificate expiry.	Historical control is not current control. Expired certification cannot pass a current certified-only filter.
Recall / legal restrictions	Independent official update feeds, scheduled checks and event invalidation; do not wait for the next scan.	Preserve active warnings; report unavailable or stale checks. No fetched alert is not proof of no recall.
Filings / size / reference data	Follow publication cadence; keep fiscal year and reference release.	A recent download does not make an old annual observation current.

These windows are initial design choices, not provider permissions or service-level commitments. A source-specific policy supplies the actual limits; safety-sensitive windows need evidence before production use.

Read-through, with selective refresh

Use conditional requests and release/delta feeds when supported. Coalesce equivalent misses only within a compatible audience and licence scope. Use jitter, backoff, circuit breakers and bounded negative caching; a provider outage or unauthorised response must not become a global product-not-found result.

Use stale-while-revalidate only when both source rules and the data's consequence allow it. Technical HTTP cache directives and contractual reuse rights are separate controls. Follow no-store, private, revalidation and authenticated-response rules for HTTP caches; an application extraction pipeline also needs its own explicit source permission. [S6]

Spend grows with useful demand

Prioritise expected reuse, missing-field value and staleness risk against API cost and quota. Track hot, warm and cold records; evict cold response bodies before useful permitted assertions. Import a public bulk release when cheaper or more complete than individual calls. Keep recall monitoring independent of popularity.

Do not rotate across users' credentials to evade quotas or use one user's subscription as an unapproved harvesting pool. Background refresh needs an authorised purpose, visible frequency and budget. Cancelling or disconnecting a grant stops its queued work.

5. Privacy and anonymised observations

Separate product facts from evidence that a person searched, bought or ate a product. A GTIN by itself may describe a product; a GTIN linked to a rare diet, exact time, store and household can describe a person. Removing a name or hashing an account ID is not enough to declare the record anonymous. [S3]

Input	Private treatment	Candidate shared output
Credential response	Keep secrets in a vault and account-bound results in the private scope.	Only provider-authorised factual fields, detached from the requesting profile and checked for personal content.
Receipt or order	Redact payment, address, loyalty and transaction identifiers; retain privately only as needed.	Permitted product identifiers or validated aggregate price observations, without reconstructable shopping trips.
Package photo	Remove EXIF; crop to the label; reject incidental faces, addresses and receipt fragments.	User-authorised, rights-eligible image or extracted product facts, marked as contributed until verified.
Search and scan activity	Short, purpose-limited operational retention; no public per-person sequences.	Coarse demand counts after aggregation and re-identification review.
Diet and health profile	Keep private; minimize inference and access. Family membership does not imply permission.	No shared person-level health or religious dietary profile. Any research aggregate needs a separate reviewed purpose.
Grower / sole trader	Public register status does not remove the need to assess personal information.	Relevant business facts; avoid unnecessary home addresses and personal contact details.

Aggregation is its own admission path

Use an allowlist of useful measures, coarse time/location buckets, contribution limits, small-cell suppression and protection against repeated-query differencing. Consider differential privacy for published behavioural statistics. Set thresholds from a risk assessment; a fixed cohort size is not proof of anonymity.

Assess the whole information environment: OffMenu's retained linkage, recipients, other available datasets and the possibility of reconstructing an individual. A shared output can have no visible profile ID while OffMenu's underlying linked records remain personal data. Reassess when new data or audiences are added. [S3]

Provenance without public user tracking

Publish source, observation date, method and confidence where permitted. Keep any necessary contributor-to-evidence link in a separate restricted ledger with a defined retention purpose. Do not publish a stable contributor ID by default or label linked internal audit records anonymous.

6. Connection and contribution experience

Use one clear connection flow and durable settings rather than repeated prompts. Terms and a privacy notice explain the system; a concise connection screen explains what will actually happen for that service. Optional contribution needs an appropriate separate choice, not a blanket assumption from accepting terms. [S4]

Control	User-facing meaning	Default proposal
Connect service	Allow OffMenu to request specific records using this account and display/cache them for me where permitted.	Narrow scopes; show refresh behaviour, retention and possible provider charges.
Contribute eligible facts	Allow qualifying product/price observations from my activity to improve the catalogue after the required checks.	Optional and separate from private connection use; never promises all provider results can be shared.
Contribute aggregate activity	Allow specified, privacy-reviewed statistics to improve coverage and refresh priorities.	Separate from product-fact contribution. No automatic reuse for advertising or model training.
Refresh while away	Allow scheduled refresh of named datasets for this profile and purpose.	Bounded frequency, quota and spend; easily paused.
Disconnect / delete	Stop further access and manage private retained records.	Revoke tokens, cancel jobs and invalidate affected access immediately; apply documented deletion rules.

Suggested plain-language disclosure for review

"OffMenu can retrieve information from services you connect and cache permitted results to make your experience faster. If you choose to contribute, eligible product facts and approved aggregate observations may improve OffMenu's shared catalogue. We apply provider permissions and privacy checks before sharing. We do not share your credentials or publish your personal shopping history. You can manage connections and contribution choices in Settings."

This is product-copy guidance, not final legal terms. The final wording must accurately describe the implemented retention, regional processing, recipients, rights and withdrawal behaviour. Consent is not the only possible legal basis, and accepting terms is not a universal basis for every secondary use.

What happens when consent or access changes

Version the choice and purpose. Re-check them at job start, before committing new data and before serving private output. A queued job must not publish after a relevant withdrawal. Stop future contribution and remove pending contributions or private linkage according to the applicable rules.

Remove retained provider data when its agreement requires this. A lawfully acquired public fact or independently sourced assertion may remain where retention is permitted; it must not depend on a revoked private record. Explain any limits on reversing already anonymous aggregates or authorised public releases before contribution, rather than promising universal retroactive deletion.

Provide profile, organisation and household controls separately. Use age-appropriate processes where children are involved. A member cannot authorise access to another member's account merely by joining a household.

7. Worked outcomes and boundaries

Scenario	What OffMenu should do
First scan of an unknown product	Check eligible cached facts, retrieve permitted public data, create source-backed assertions and return a partial result. Ask for a label photo only if the gap matters. Subsequent users can reuse admitted facts.
Connected retailer returns ingredients and a loyalty price	Classify fields separately. Ingredients can enter shared storage only if reuse is granted; the personal offer remains private. Neither user consent nor anonymisation creates missing retailer rights.
One paid ownership lookup resolves a parent company	Keep it within its licensed audience. Public promotion or cross-user derived boycott results require compatible provider rights. An accessible public filing can supply separate evidence only through a permitted independent retrieval.
Three source facts produce a dietary outcome	Check rights and freshness for all essential inputs. Keep rule version and evidence. Unknown certification scope or ingredients yields unknown, not a positive suitability result.
A new recall arrives for a cached product	Update affected product/lot/market links and invalidate derived suitability views. All-batch notices do not need a lot. Do not delete a warning just because a cache timer ends.
A source revokes reuse permission	Stop affected reads/publication immediately, invalidate derived views, delete required copies and rebuild from still-permitted evidence. A normalized copy is still within the dependency graph.
Many users scan the same product	Deduplicate eligible shared fetches; do not share private prices, tokens or entitlements. Count demand only through the approved privacy path.
A browser extension reads a user session	Use only service-permitted actions and selected data transfer. Do not export browser cookies into a shared pool or treat browser access as permission to mirror the service.

Operational isolation

Serve a mixed public/private response through a private endpoint with no shared CDN caching. If useful, split independently reusable public fields into a separate response. Redact secrets and bodies in logs, tracing, error reporting and queue payloads. Search indexes, embeddings, exports and analytics must enforce the same audience and rights rules.

Keep cache insertion idempotent and version-aware. Validate webhook origin and sequence; prevent older delayed responses from overwriting newer evidence. Quarantine suspicious identifiers, impossible units, contradictory changes and high-impact ownership or safety edits. Do not trust an anonymous user's supplied source URL or product match as authoritative.

8. Delivery plan and acceptance evidence

Build the smallest coherent system first: a source-policy registry, credential vault, request resolver, connector workers, scoped caches, assertion store and promotion log. A relational store can hold identities/policies/assertions; a fast cache serves hot reads; permitted payloads use object storage; queues schedule work. Select concrete services against the current product stack later.

Stage	Deliverable	Evidence before widening use
1. Public foundation	Admit reviewed public sources; preserve licence partitions, provenance and product versions.	Warm-cache reuse works; incompatible rights are not flattened; old facts keep dates; source removal invalidates dependent views.
2. Private connections	Add per-profile/organisation grants, refresh controls, entitlement checks and budgets.	Two accounts cannot read each other's results; revocation blocks cached access and queued jobs; secrets stay out of logs.
3. Controlled promotion	Enable field allowlists for providers with explicit reuse rights; add contribution choices and evidence review.	Mixed responses split correctly; unknown rights remain unshared; derived outputs cannot escape an input restriction.
4. Aggregation and breadth	Add reviewed aggregate observations and broaden source/country coverage by measured value.	Sparse records and repeated queries do not reveal users; regional rules and provider quotas are enforced.

Acceptance scenarios that matter

Test expiry during an in-flight refresh; a licence narrowing after a record is cached; revoked consent between fetch and publication; same GTIN with different country recipes; personalised and public prices; a recall during a provider outage; source retractions; late webhook events; and deletion across indexes, derivatives and backup restore.

Deletion must cover caches, retained bodies, assertions where required, search, embeddings and derived outputs. Backups need a bounded retention schedule and restore-time deletion replay; immutable backups are not an excuse to make deleted data live again. Keep only a minimal permitted audit record.

Measure quality and unit economics

Track useful fields per lookup, eligible shared hit rate, private hit rate, provider calls avoided, cost per newly validated fact, freshness by field, conflict rate, promotion rejection reasons, recall-update lag and deletion completion. Report coverage by country, language and entity type; a busy country must not hide empty coverage elsewhere.

All 249 jurisdictions

Use the existing ISO2 register for product markets, source scope and gap tracking. Add policy overlays for processing location, account/contract region, jurisdiction, field and audience. The country of the requesting user alone cannot determine all relevant rights. Do not equate 249 discovery entries with 249 completed privacy or licensing reviews.

The shared layer remains available without a user subscription where its data rights allow that. User connections supply optional additional capabilities. Safety updates, low-coverage countries and small-producer data need deliberate coverage work alongside demand-driven growth.

9. Sources and decision status

The architecture and operating defaults are proposed design decisions. The following primary sources support the external constraints and examples; they do not amount to a provider-by-provider or 249-jurisdiction legal clearance. Checked 13 October 2026 Melbourne.

S1 Google: Places API policies and attributions

Documents restrictions on prefetching, caching and storage, the place-ID exception, attribution and regional terms.

S2 Open Food Facts: API licence guidance

Identifies the database licence and points to reuse obligations. Normalization does not eliminate source rights.

S3 OAIC: De-identification and the Privacy Act

Identifiability depends on context, accessible information and realistic re-identification possibilities.

S4 OAIC: Consent to the handling of personal information

Explains the qualities of valid consent and choices about personal-information handling.

S4a OAIC: Australian entities and the EU GDPR

Discusses consent and the problem with bundled choices where separate consents are appropriate.

S5 GLEIF: Open Data

States the CC0 status of published GLEIF data. Source meaning and personal-data considerations still need attention.

S6 IETF: RFC 9111, HTTP Caching

Technical rules for shared/private caching, authenticated requests, freshness and validation. These do not themselves grant a data-reuse licence.

S7 OAIC and CSIRO Data61: De-identification decision-making framework

Practical framework to assess de-identification and release risk; use for the proposed aggregation path.

Relationship to the discovery report

Use each source_register source_id as the foreign key for new caching and reuse policies. Discovery status remains separate: a verified source means its published capability was found, not that caching or reuse is approved. Add policies and decisions without silently changing that original evidence status.

The existing 249-country report and source register remain the discovery baseline. This is a standalone design addendum. No application code, provider account, active connection, credential, data-ingestion job or privacy setting was changed.